



University of Bahrain  
College of Information Technology  
Department of Information Systems  
ITCY460 – Security Risk Assessment and Countermeasures



# Meridian FinTech Solutions

## Final Risk Management Plan

Aljazi Ali Almujaaddam – 202202227  
Dana Hussain Alhayki – 202204341  
Noora Abdulrahman Bumajaid – 202203245  
Nada Abdulaziz Yahya – 202203864  
Maram Abdulqawi Ghaleb – 202305067

# Agenda

|           |                                    |           |                                       |           |                                       |           |                                    |
|-----------|------------------------------------|-----------|---------------------------------------|-----------|---------------------------------------|-----------|------------------------------------|
| <b>01</b> | <b>Executive Summary</b>           | <b>02</b> | <b>Introduction</b>                   | <b>03</b> | <b>Company Background</b>             | <b>04</b> | <b>Scope and Boundaries</b>        |
| <b>05</b> | <b>Compliances and Regulations</b> | <b>06</b> | <b>Roles and Responsibilities</b>     | <b>07</b> | <b>Key Assets</b>                     | <b>08</b> | <b>Threats and Vulnerabilities</b> |
| <b>09</b> | <b>Risk Assessment Overview</b>    | <b>10</b> | <b>Risk Prioritization</b>            | <b>11</b> | <b>Risk Mitigation Strategies</b>     | <b>12</b> | <b>Risk-to-Mitigate Mapping</b>    |
| <b>13</b> | <b>Cost-Benefit Analysis</b>       | <b>14</b> | <b>Business Impact Analysis (BIA)</b> | <b>15</b> | <b>Business Continuity Plan (BCP)</b> | <b>16</b> | <b>Monitoring and Review</b>       |
|           |                                    | <b>17</b> | <b>Implementation Schedule</b>        | <b>18</b> | <b>Conclusion</b>                     |           |                                    |

**01**

# **Executive Summary**

# Executive Summary

## Meridian FinTech Solutions

- Cloud-based fintech company using AWS and GCP
- Core platforms: Pay-API, Fraud-Shield, Currency-X, Wallet-Link, Fin-Report
- Handles sensitive financial and customer data

## Main Risks Identified

- Hard-coded API keys
  - Insider threats
  - BEC attacks
- Weak BYOD security
  - Shadow IT usage
    - Cloud misconfiguration
- No centralized SIEM

## Proposed Security Controls

- Stronger BYOD policy
- Secure coding & API key rotation
  - IAM enforcement
- SIEM implementation
- MFA & MDM solutions
- Phishing awareness training
  - Physical security improvements

**02**

# **Introduction**



# Introduction

**Meridian FinTech Solutions** is a global fintech company that provides **cloud-based payment** and **financial services**.

Because it handles **sensitive customer data**, it faces **cybersecurity** and **operational risks** from both **internal** and **external sources**.

Therefore, a Risk Management Plan is **needed to identify** and **reduce these risks**.

**03**

# **Company Background**

# Company Background

Meridian operates globally with offices in **San Francisco, London,** and **Tokyo,** serving thousands of customers.

It earns revenue through **transaction** and **subscription fees** and **offers services** like Pay-API, Fraud-Shield, and Currency-X.

The company uses **AWS** and **GCP** for cloud services, which provide **flexibility** but also **increase cybersecurity risks.**



**04**

# **Scope and Boundaries**

# Scope and Boundaries

## Scope Includes:

- AWS production environment
- GCP failover environment

### Key risks:

- API key exposure
- Shadow IT
- Phishing & BEC
- Cloud misconfiguration
- No centralized SIEM

### Core platforms:

- Pay-API
- Fraud-Shield
- Currency-X
- Wallet-Link
- Fin-Report
- Golden Record database

- Employee devices (MacBooks & BYOD)
- BIA and BCP activities

# Scope and Boundaries

## Boundaries

### Excludes:

- Retailer systems connected via Pay-API
- Partner banking systems via Currency-X
- Customer-owned Wallet-Link devices
  - Coding details & technical configurations

### Includes:

- Internal Shadow IT risks
- Unmanaged employee BYOD risks

**05**

# **Compliances and Regulations**

# Compliances and Regulations

Meridian must follow **several regulations** because it processes **financial data** across different countries.

These include **PCI DSS** for **payment security**, **GDPR** for **data protection**, and **AML** for **financial monitoring**.

It also follows **ISO 27001** for **information security** and **NIST SP 800-30** for **risk assessment**.

**Following** these regulations **helps** protect data, reduce risks, and avoid legal penalties.



**06**

# **Roles and Responsibilities**

# Roles & Responsibilities

## Senior Management

- Approve strategy
- Allocate resources
- Support continuity decisions

## Risk / Project Management Team

- Coordinate risk assessment
- Monitor mitigation activities
- Report to management

## IT Operations Team

- Maintain AWS & GCP infrastructure
- Support failover and recovery

## Information Security Team

- Identify threats
- Implement SIEM, IAM, MFA, endpoint protection

# Roles & Responsibilities

## Risk & Compliance Team

- Ensure compliance with:  
PCI DSS - GDPR - ISO 27001  
- NIST SP 800-30

## Department Managers

- Communicate policies
- Report incidents

## Employees

- Follow security policies
- Report suspicious activity

## Cloud Providers (AWS / GCP)

- Support infrastructure only



**07**

# **Key Assets**

# Key Assets

## 1. Information Assets

- Customer financial data & transaction history
- Golden Record database
- Payment records & AML reports

## 2. Systems / Applications

- Pay-API, Fraud-Shield
- Currency-X, Wallet-Link
- Fin-Report

## 3. Infrastructure

- AWS (production environment)
- GCP (disaster recovery / failover)
- Cloud services (compute, network, storage)

# Key Assets

## 4. Hardware / Endpoints

- Encrypted MacBooks
- BYOD mobile devices
- Remote access tools

## 5. Personnel

- DevOps & IT/Security teams
- Finance staff
- Employees using systems

## 6. Intangible Assets

- Company reputation & customer trust
- SLA commitments
- Proprietary algorithms
- Client relationships

08

# Threats and Vulnerabilities

# Major Threats and Vulnerabilities



## Key Threats:

- Insider threat (terminated employee – API key misuse)
- Business Email Compromise (BEC) & phishing attacks
- Cyberattacks on cloud infrastructure (AWS/GCP)
- Data breaches of financial & customer data
- Cloud service outages
- Social engineering attacks
- Regulatory non-compliance (PCI DSS, GDPR, AML)



# Major Threats and Vulnerabilities



## Key Vulnerabilities:

- Hard-coded API credentials
- Lack of centralized SIEM monitoring
- Shadow IT (unauthorized communication apps)
- Weak BYOD security controls
- Poor access control after employee termination
- Weak email security & anti-phishing measures
- Inadequate log monitoring and correlation

09

# **Risk Assessment Overview**

# Risk Assessment Summary

## Assessment Approach:

- *Qualitative Risk Assessment*
- *Based on **Likelihood** × **Impact***
- *Risks classified as: High / Medium / Low*

## Key Findings:

- *Majority of risks are High Risk*
- *High likelihood + high impact on operations*
- *Direct impact on Confidentiality, Integrity, Availability (CIA)*

## Top Critical Risks:

- *Unauthorized access (hard-coded API keys)*
- *Business Email Compromise (BEC)*
- *Lack of centralized SIEM monitoring*
- *Cloud security risks (AWS/GCP)*



**10**

# **Risk Prioritization**

# Risk Prioritization

## Risk Levels:

| Threat / Vulnerability                       | Likelihood | Impact | Risk Rating | Priority Level |
|----------------------------------------------|------------|--------|-------------|----------------|
| Hard-coded API key (insider threat)          | High       | High   | Critical    | Immediate      |
| Business Email Compromise (Tokyo)            | High       | Medium | High        | Immediate      |
| BYOD unpatched devices                       | Medium     | High   | High        | Immediate      |
| External attacks (DDoS, ransomware)          | Medium     | High   | High        | Immediate      |
| Human factors (phishing/social engineering)  | High       | Medium | High        | Immediate      |
| Physical security weaknesses                 | Medium     | High   | High        | Immediate      |
| Cloud misconfigurations (IAM roles, buckets) | Medium     | Medium | Moderate    | Mid-Term       |
| Shadow IT communications                     | Medium     | Medium | Moderate    | Mid-Term       |
| Lack of centralized SIEM                     | Low        | High   | Moderate    | Mid-Term       |

- **High Risk** → Immediate mitigation required
- **Medium Risk** → Planned mitigation
- **Low Risk** → Acceptable with monitoring

**11**

# **Risk Mitigation Strategies**

# Mitigation Objectives:

- Reduce the likelihood and impact of risks
- Strengthen security controls
- Improve system monitoring and detection
- Enhance overall system resilience

# Key Mitigation Strategies:

- Eliminate hard-coded API credentials
- Implement SIEM for centralized monitoring
- Enhance email security & anti-phishing training
- Apply MDM for BYOD device control
- Improve access control (RBAC, MFA)
- Ensure cloud redundancy (AWS  $\leftrightarrow$  GCP failover)



# Risk Treatment Approach:

- Mitigate → apply security controls
- Avoid → eliminate risky practices
- Transfer → use third-party/insurance
- Accept → low-impact risks

# Residual Risk:

- Some risks remain after mitigation
- Continuously monitored and reviewed

12

# **Risk-to-Mitigate Mapping**



# Risk-to-Mitigate Mapping

| Threat / Vulnerability                       | Risk Rating | Mitigation Strategy                                                                                                                      | Control Category           | Implementation Notes                                                                               |
|----------------------------------------------|-------------|------------------------------------------------------------------------------------------------------------------------------------------|----------------------------|----------------------------------------------------------------------------------------------------|
| Hard-coded API key (insider threat)          | Critical    | Rotate/revoke API keys, enforce secure coding standards, automate secret scanning, strict termination procedures                         | Administrative / Technical | Immediate action: IT Security to rotate keys and audit source code within 1 month                  |
| Business Email Compromise (Tokyo)            | High        | Deploy advanced email filtering, enforce DMARC/SPF/DKIM, conduct phishing awareness training, and implement financial approval workflows | Administrative             | Short-term: Training rolled out in Tokyo office; Technical email controls deployed within 3 months |
| BYOD unpatched devices                       | High        | Enforce BYOD policy, deploy Mobile Device Management (MDM), mandatory patching, and endpoint encryption                                  | Administrative / Technical | Mid-term: MDM rollout across all employee devices within 6 months                                  |
| Cloud misconfigurations (IAM roles, buckets) | Moderate    | IAM role reviews, automated compliance checks, least-privilege enforcement, CIS benchmark alignment                                      | Technical                  | Mid-term: Automated compliance tools deployed within 6 months                                      |

# Risk-to-Mitigate Mapping

|                                             |          |                                                                                                    |                |                                                                              |
|---------------------------------------------|----------|----------------------------------------------------------------------------------------------------|----------------|------------------------------------------------------------------------------|
| Lack of centralized SIEM                    | Moderate | Deploy a centralized SIEM solution, integrate AWS/GCP logs, and enable real-time monitoring        | Technical      | Mid-term: SIEM deployment planned within 6 months                            |
| Shadow IT communications                    | Moderate | Enforce approved collaboration tools, awareness campaigns, and monitor unauthorized apps           | Administrative | Short-term: HR to update policies and enforce official tools within 3 months |
| Human factors (phishing/social engineering) | High     | Security awareness training, simulated phishing campaigns, and stronger MFA enforcement            | Administrative | Ongoing: Quarterly training and simulated phishing exercises                 |
| External attacks (DDoS, ransomware)         | High     | DDoS protection (AWS Shield), endpoint detection and response (EDR), regular backups, IDS/IPS      | Technical      | Immediate: AWS Shield enabled; Long-term: EDR rollout across all systems     |
| Physical security weaknesses                | High     | Office access control systems, surveillance cameras, visitor management, and secure device storage | Physical       | Short-term: Access control upgrades in Tokyo office within 3 months          |

**13**

# **Cost–Benefit Analysis**

# Cost-Benefit Analysis

| Risk                          | Countermeasure                   | Loss Before | Loss After | Projected Benefit | Cost     | Countermeasure Value |
|-------------------------------|----------------------------------|-------------|------------|-------------------|----------|----------------------|
| Cloud misconfiguration        | SIEM implementation              | \$200,000   | \$70,000   | \$130,000         | \$50,000 | \$80,000             |
| API key misuse/insider threat | IAM enforcement+ secret scanning | \$150,000   | \$40,000   | \$110,000         | \$30,000 | \$80,000             |
| Phishing/BEC attacks          | Awareness training program       | \$120,000   | \$30,000   | \$90,000          | \$20,000 | \$70,000             |
| BYOD device exposure          | MDM solution                     | \$100,000   | \$35,000   | \$65,000          | \$25,000 | \$40,000             |

14

# **Business Impact Analysis (BIA)**



# Purpose:

- Identify critical business functions
- Assess impact of disruptions
- Define recovery time requirements

# Critical Business Functions:

- Pay-API → payment processing
- Fraud-Shield → fraud detection
- Fin-Report → compliance reporting
- Cloud Infrastructure (AWS/GCP)
- Wallet-Link → customer transactions

# Potential Impacts:

- Financial loss from failed transactions
- Damage to reputation & customer trust
- Regulatory penalties (PCI, GDPR, AML)
- Service downtime
- Data loss or corruption



# Recovery Objectives:

| Business Function                   | MAO<br>(Maximum Acceptable Outage) | RTO<br>(Recovery Time Objective) | RPO<br>(Recovery Point Objective) |
|-------------------------------------|------------------------------------|----------------------------------|-----------------------------------|
| Payment Processing<br>(Pay-API)     | 1 hour                             | 30 minutes                       | Near real-time                    |
| Fraud Detection<br>(Fraud-Shield)   | 1 hour                             | 30 minutes                       | Near real-time                    |
| Financial Reporting<br>(Fin-Report) | 4 hours                            | 2 hours                          | 1 hour                            |
| Wallet Services<br>(Wallet-Link)    | 2 hours                            | 1 hour                           | 30 minutes                        |
| Cloud Infrastructure                | 1 hour                             | 30 minutes                       | Near real-time                    |

**15**

# **Business Continuity Plan (BCP)**

# Objective:

- Maintain operations during disruptions
- Minimize downtime and service interruption

# Continuity Strategy:

- Multi-cloud approach (AWS + GCP)
- Cloud failover (automatic switching)
- Redundancy (multiple availability zones)
- Load balancing for system stability

# Backup & Recovery:

- Automated data backups
- Real-time / near real-time replication
- Secure off-site storage
- Regular backup verification



# Incident Response:

- Detect → Contain → Recover → Verify → Communicate

# Testing & Maintenance:

- Regular drills & simulations
- Annual testing (minimum)
- Continuous improvement

**16**

# **Monitoring and Review**

# Objective:

- Ensure continuous risk management
- Detect new threats and vulnerabilities
- Maintain effectiveness of controls



# Continuous Monitoring:

- Real-time system and security monitoring
- Log collection & analysis (AWS & GCP)
- SIEM for centralized monitoring
- Detection of anomalies & unauthorized access

# Risk Review & Audits:

- Periodic risk reassessment
- Evaluate effectiveness of controls
- Compliance audits (PCI DSS, GDPR, AML)

# Plan Updates:

- Regular updates (semi-annual)
- Based on:
  1. System changes
  2. New threats
  3. Audit results

17

# Implementation Schedule

| Phase   | Activity                        | Description                                                                             | Responsible Party           | Duration | Start Date | End Date | Resources                                          |
|---------|---------------------------------|-----------------------------------------------------------------------------------------|-----------------------------|----------|------------|----------|----------------------------------------------------|
| Phase 1 | Project Initiation & Planning   | Define scope, objectives, stakeholders, and risk management methodology (NIST-based)    | Project Manager & Risk Team | 1 week   | Mar 25     | Mar 31   | Project plan, NIST guidelines, documentation tools |
| Phase 2 | Asset Identification            | Identify critical assets (AWS, GCP, APIs, financial data, infrastructure)               | IT & Security Team          | 1 week   | Apr 1      | Apr 7    | Asset inventory tools, cloud dashboards            |
| Phase 3 | Threat & Vulnerability Analysis | Identify threats (BEC, cyberattacks) and vulnerabilities (API keys, Shadow IT, no SIEM) | Security Team               | 1 week   | Apr 8      | Apr 14   | Security reports, logs, threat intelligence tools  |



|                |                            |                                                                          |                      |        |        |        |                                   |
|----------------|----------------------------|--------------------------------------------------------------------------|----------------------|--------|--------|--------|-----------------------------------|
| <b>Phase 4</b> | Risk Assessment            | Evaluate risks using likelihood and impact (risk matrix)                 | Risk Management Team | 1 week | Apr 15 | Apr 21 | Risk matrix, assessment tools     |
| <b>Phase 5</b> | Control Assessment         | Evaluate existing controls (MFA, monitoring gaps, missing SIEM)          | IT & Security Team   | 1 week | Apr 22 | Apr 28 | Security tools, audit reports     |
| <b>Phase 6</b> | Risk Mitigation Planning   | Define mitigation strategies (SIEM, API security, email protection, MDM) | Management & IT      | 1 week | Apr 29 | May 5  | Risk frameworks, policy documents |
| <b>Phase 7</b> | Control Selection & Design | Select and design appropriate controls for implementation                | Security Team        | 1 week | May 6  | May 12 | Security solutions, vendor tools  |

|                 |                                             |                                                                                    |                        |         |        |        |                                                   |
|-----------------|---------------------------------------------|------------------------------------------------------------------------------------|------------------------|---------|--------|--------|---------------------------------------------------|
| <b>Phase 8</b>  | Implementati<br>on Planning                 | Plan deployment<br>steps, allocate<br>resources, assign<br>responsibilities        | Project<br>Manager     | 1 week  | May 13 | May 19 | Project planning<br>tools                         |
| <b>Phase 9</b>  | Risk<br>Mitigation<br>Implementati<br>on    | Deploy controls<br>(SIEM, API<br>security, email<br>security, MDM<br>systems)      | IT & Security<br>Teams | 2 weeks | May 20 | Jun 2  | SIEM tools, API<br>security tools,<br>MDM systems |
| <b>Phase 10</b> | Business<br>Impact<br>Analysis<br>(BIA)     | Identify critical<br>functions, MAO,<br>RTO, RPO, and<br>impact of<br>disruptions  | Risk Team              | 1 week  | Jun 3  | Jun 9  | Financial data,<br>analysis tools                 |
| <b>Phase 11</b> | Business<br>Continuity<br>Planning<br>(BCP) | Develop recovery<br>strategies,<br>failover plans,<br>and continuity<br>procedures | Management<br>& IT     | 1 week  | Jun 10 | Jun 16 | Backup systems,<br>cloud failover<br>tools        |

|                 |                        |                                                           |                     |         |        |         |                                        |
|-----------------|------------------------|-----------------------------------------------------------|---------------------|---------|--------|---------|----------------------------------------|
| <b>Phase 12</b> | Testing & Validation   | Test controls, disaster recovery, and failover mechanisms | IT & Security Teams | 1 week  | Jun 17 | Jun 23  | Testing tools, simulation environments |
| <b>Phase 13</b> | Final Reporting        | Document final RMP, findings, and recommendations         | Project Team        | 1 week  | Jun 24 | Jun 30  | Documentation tools                    |
| <b>Phase 14</b> | Monitoring & Review    | Continuous monitoring of risks and system performance     | Security Team       | Ongoing | Jul 1  | Ongoing | SIEM dashboards, monitoring tools      |
| <b>Phase 15</b> | Continuous Improvement | Update plan, improve controls, and adapt to new threats   | Risk Manager        | Ongoing | Jul 1  | Ongoing | Audit reports, feedback tools          |



**18**

# **Conclusion**

# Conclusion

Meridian faces **cybersecurity** and **operational risks** due to its reliance on **cloud systems** and **sensitive data**.

A strong Risk Management Plan, including assessment, mitigation, BIA, and BCP, **helps reduce these risks**.

Implementing controls like **BYOD policies** and **monitoring systems** improves security.

Overall, effective risk management ensures **security, business continuity,** and **success**.

# Thank you

**Any Questions?**